

Secure and Robust Federated Learning

Distinguishing Malicious Updates from Legitimate Non-IID Variation

Yohannes Alelign Biresaw

Prospective MSc thesis proposal

Prepared by Yohannes Alelign Biresaw

August 2026

Executive summary

Federated learning enables several clients to train a shared model while retaining raw data locally. This architecture is attractive for sensitive domains, but it creates a difficult security problem: a malicious client can submit poisoned updates, while an honest client with genuinely different data may also produce an unusual update. Robust aggregation rules are intended to limit malicious influence, yet many were developed under homogeneous or simplified assumptions. Under non-IID data, natural variation among honest updates can cause a defense to reject legitimate clients or preserve carefully designed attacks.

The proposed research will investigate how robust aggregation can protect a federated classifier from malicious clients without suppressing legitimate non-IID participation. Chest radiography will provide a controlled high-stakes testbed built on a completed patient-aware FedAvg/FedProx pipeline. Evaluation will include global utility, benign-client false rejection, malicious-client detection, worst-client performance, calibration, attack success, and computational cost.

1. Motivation and background

FedAvg aggregates client models by weighted averaging [1]. It is effective when clients are reliable, but an adversary can exploit the averaging step by submitting arbitrary updates. Krum, coordinate-wise median, trimmed mean, geometric-median aggregation, and trust-based methods were developed to reduce Byzantine or poisoning influence [4,5,7,8]. Model-poisoning research has shown that defenses can remain vulnerable to carefully optimized updates [6].

Data heterogeneity makes the security problem harder. Honest non-IID clients may be far from the global update because they represent uncommon classes, acquisition protocols, or populations. Recent work has shown that heterogeneous gradients can undermine robust aggregation, produce selection bias, and make malicious clients difficult to distinguish from benign outliers [9-13,15]. This issue is relevant in medical imaging, where rare findings and institutional differences may be clinically legitimate [14,16].

2. Preliminary research foundation

The completed project evaluated centralized training, FedAvg, and FedProx using the RSNA Pneumonia Detection Challenge dataset [17]. It used 26,684 examinations linked to 11,452 patients, patient-exclusive splits, five-client IID and non-IID partitions, three seeds, validation-only selection, and one frozen final evaluation of 18 models.

Condition	ROC-AUC	PR-AUC	Balanced accuracy	F1-score
Centralized	0.8295 $\pm$ 0.0040	0.5800 $\pm$ 0.0057	0.7510 $\pm$ 0.0037	0.5745 $\pm$ 0.0107
FedAvg IID	0.8179 $\pm$ 0.0030	0.5605 $\pm$ 0.0042	0.7453 $\pm$ 0.0048	0.5695 $\pm$ 0.0068
FedAvg moderate non-IID	0.8131 $\pm$ 0.0027	0.5553 $\pm$ 0.0065	0.7355 $\pm$ 0.0032	0.5541 $\pm$ 0.0055
FedAvg severe non-IID	0.8070 $\pm$ 0.0005	0.5440 $\pm$ 0.0043	0.7312 $\pm$ 0.0020	0.5529 $\pm$ 0.0029
FedProx moderate non-	0.8112 $\pm$ 0.0020	0.5505 $\pm$ 0.0040	0.7375 $\pm$ 0.0050	0.5608 $\pm$ 0.0036

Condition	ROC-AUC	PR-AUC	Balanced accuracy	F1-score
IID				
FedProx severe non-IID	0.8076 ± 0.0019	0.5428 ± 0.0092	0.7335 ± 0.0030	0.5581 ± 0.0076

Stronger heterogeneity reduced predictive performance. FedProx reduced client and global update magnitudes by roughly one-half but did not consistently improve ranking performance. Legitimate non-IID behaviour therefore changed update geometry substantially even before malicious clients were introduced.

3. Research problem and novelty

Many robust aggregation methods treat distant or unusual client updates as suspicious. In a heterogeneous federation, distance from the majority can reflect either malicious manipulation or valid local data. A defense that removes too many honest updates may harm minority clients, rare classes, or underrepresented acquisition settings.

How can federated aggregation resist malicious-client attacks while preserving legitimate updates generated by non-IID client data?

The general problem is active rather than unexplored: nearest-neighbour mixing, gradient splitting, BOBA, SDEA, and BPFLH address Byzantine robustness under heterogeneity [9-13,15]. The proposed contribution is a focused and reproducible medical-imaging benchmark with explicit measurement of benign-client rejection, minority-client harm, and clinically meaningful utility.

4. Aim and objectives

Aim: To evaluate and improve the security-utility trade-off of robust federated aggregation under simultaneous client heterogeneity and malicious participation.

1. Define a clear cross-silo threat model for malicious-client participation.
2. Extend the existing patient-aware pipeline to a client count suitable for robust-aggregation evaluation.
3. Implement representative untargeted and targeted poisoning attacks.
4. Compare standard and heterogeneity-aware aggregation defenses.
5. Measure global utility, worst-client utility, calibration, attack success, malicious-client detection, and benign-client false rejection.
6. Identify conditions in which a defense mistakes legitimate non-IID updates for attacks.
7. Produce a reproducible experimental package and practical recommendations.

5. Research questions

8. How do label and view-position heterogeneity affect the separability of honest and malicious updates?
9. Which robust aggregation methods best preserve PR-AUC and worst-client performance under attack?

10. How often do defenses reject honest clients from minority data distributions?
11. How do malicious-client fraction, attack strength, and local-training duration change the security-utility trade-off?
12. Can a simple heterogeneity-aware trust or grouping mechanism reduce benign-client rejection without increasing attack success?

6. Threat model

The primary setting will be cross-silo federated learning with an honest coordinating server and a fixed set of clients. A bounded fraction of clients may be malicious. Malicious clients can observe the current global model and manipulate their local data, training process, or submitted update. They do not initially observe honest clients' private data. Full participation will be used in the main experiments to isolate aggregation behaviour; partial participation may be studied as an extension because subsampling changes the effective malicious fraction [12].

The server will inspect individual updates in the primary robustness experiments. This creates a privacy-security tension because secure aggregation hides individual updates, while many robust defenses rely on examining them. The thesis will state this limitation explicitly.

7. Proposed methodology

7.1 Data and client construction

- Approximately IID clients
- Dirichlet label skew
- AP/PA view-position skew as an acquisition proxy
- Combined label and view-position heterogeneity

Clients will remain patient-exclusive. The existing held-out test set will not be reused for iterative security development. A new independent evaluation protocol or external compatible dataset will be defined with the supervisor.

7.2 Attacks

- Sign-flip or scaled-gradient attack
- Model-replacement attack
- Label-flipping data poisoning
- Optional targeted backdoor attack if scope and compute permit

7.3 Aggregation baselines

Method	Core idea	Concern under heterogeneity
FedAvg	Weighted mean	Highly sensitive to malicious updates
Coordinate-wise median	Median per parameter	May ignore useful honest variation
Trimmed mean	Remove coordinate extremes	May bias minority clients
Krum / Multi-Krum	Select neighbouring updates	Non-IID data can distort distance

Method	Core idea	Concern under heterogeneity
Geometric median / RFA	Robust central update	May underrepresent minority directions
FLTrust	Server-rooted trust	Requires trusted server data
Heterogeneity-aware method	Grouping or correction	Adds complexity and assumptions

A new aggregation rule will be attempted only if baseline analysis identifies a clear and reproducible failure mode.

7.4 Evaluation

- PR-AUC, ROC-AUC, balanced accuracy, F1-score, sensitivity, and specificity
- Calibration error and Brier score
- Worst-client and minority-client performance
- Attack success or utility degradation
- Malicious-client detection or down-weighting rate
- Benign-client false rejection rate
- Update norm and cosine-similarity diagnostics
- Aggregation time and communication cost where relevant

7.5 Experimental design

Conditions will be repeated across prespecified seeds. Comparisons will pair algorithm, partition, attack, malicious fraction, and seed. Primary hypotheses and metrics will be defined before final evaluation. Means, standard deviations, paired differences, and confidence intervals will be reported when repetition count supports them. Ablations will separate heterogeneity, attack type, malicious fraction, local epochs, and any trust or grouping component. Attack-free robustness cost will also be reported.

8. Expected contributions

13. A reproducible security benchmark built on patient-aware federated medical imaging.
14. Evidence showing when robust aggregators confuse legitimate non-IID updates with malicious behaviour.
15. Evaluation of benign-client false rejection and worst-client harm alongside global utility.
16. Practical guidance for selecting robust aggregation under different threat and heterogeneity conditions.
17. An optional heterogeneity-aware trust or grouping method if baseline evidence supports a clear need.

9. Feasibility and risk management

The completed pipeline already provides DICOM preprocessing, patient-aware splitting, client partitioning, CNN training, multi-seed evaluation, and frozen-test controls. The main new components are attacks, robust aggregators, client-level diagnostics, and a separate evaluation protocol. Scope will prioritize two attack families and four to six aggregators before optional

backdoor or new-method work. Compute will be managed through staged smoke tests, cached images, a compact CNN, and a prespecified experiment matrix.

10. Ethics, security, and responsible use

The primary data are public and de-identified. No new patient data will be collected. The work will avoid implying that simulated clients are real hospitals or that federated learning alone provides privacy. Attack code will be documented for defensive research and evaluated in a controlled environment. Any institutional-data extension would require ethics, governance, and security approval.

11. Indicative 12-month plan

Period	Activity
Months 1-2	Literature review, threat model, protocol, and baseline reproduction
Months 3-4	Client expansion, attack implementations, and validation tests
Months 5-6	Robust aggregation baselines and attack-free cost analysis
Months 7-8	Combined heterogeneity and attack experiments
Months 9-10	Client diagnostics, ablations, and optional method extension
Month 11	Final evaluation, figures, and statistical summary
Month 12	Thesis writing, revision, and repository release

12. Research fit

This proposal defines a focused thesis at the intersection of machine learning and cybersecurity: the security and robustness of distributed learning under realistic client heterogeneity. It can be adapted to a supervisor's expertise in federated learning, adversarial machine learning, trustworthy AI, privacy-preserving computation, or distributed-system security without presenting the applicant as a specialist in unrelated areas.

References

- [1] B. McMahan et al., 'Communication-Efficient Learning of Deep Networks from Decentralized Data,' AISTATS, 2017.
- [2] T. Li et al., 'Federated Optimization in Heterogeneous Networks,' MLSys, 2020.
- [3] S. P. Karimireddy et al., 'SCAFFOLD: Stochastic Controlled Averaging for Federated Learning,' ICML, 2020.
- [4] P. Blanchard, E. M. El Mhamdi, R. Guerraoui, and J. Stainer, 'Machine Learning with Adversaries: Byzantine Tolerant Gradient Descent,' NeurIPS, 2017.
- [5] D. Yin, Y. Chen, K. Ramchandran, and P. Bartlett, 'Byzantine-Robust Distributed Learning: Towards Optimal Statistical Rates,' ICML, 2018.
- [6] M. Fang, X. Cao, J. Jia, and N. Gong, 'Local Model Poisoning Attacks to Byzantine-Robust Federated Learning,' USENIX Security, 2020.

- [7] X. Cao, M. Fang, J. Liu, and N. Z. Gong, 'FLTrust: Byzantine-Robust Federated Learning via Trust Bootstrapping,' NDSS, 2021.
- [8] K. Pillutla, S. M. Kakade, and Z. Harchaoui, 'Robust Aggregation for Federated Learning,' IEEE Transactions on Signal Processing, vol. 70, pp. 1142-1154, 2022.
- [9] Y. Allouah et al., 'Fixing by Mixing: A Recipe for Optimal Byzantine ML under Heterogeneity,' AISTATS, 2023.
- [10] Y. Liu et al., 'Byzantine-Robust Learning on Heterogeneous Data via Gradient Splitting,' ICML, 2023.
- [11] W. Bao, J. Wu, and J. He, 'BOBA: Byzantine-Robust Federated Learning with Label Skewness,' AISTATS, 2024.
- [12] Y. Allouah et al., 'Byzantine-Robust Federated Learning: Impact of Client Subsampling and Local Updates,' ICML, 2024.
- [13] W. Huang et al., 'Self-Driven Entropy Aggregation for Byzantine-Robust Heterogeneous Federated Learning,' ICML, 2024.
- [14] P. Kulkarni et al., 'From Isolation to Collaboration: Federated Class-Heterogeneous Learning for Chest X-Ray Classification,' Machine Learning for Health, 2025.
- [15] G. Zhu, W. Shen, Z. Liu, J. Qin, and J. Ma, 'BPFLH: Byzantine-Robust Privacy-Preserving Federated Learning for Heterogeneous Data,' IEEE Transactions on Dependable and Secure Computing, 2026.
- [16] M. Karami et al., 'Byzantine Robust Federated Learning for Heterogeneous Brain MRI Using Multisignal Gradient Fingerprinting and Adaptive Trust Aggregation,' Scientific Reports, 2026.
- [17] G. Shih et al., 'Augmenting the National Institutes of Health Chest Radiograph Dataset with Expert Annotations of Possible Pneumonia,' Radiology: Artificial Intelligence, 2019.